

MODELO DE ENCUESTA INTEGRAL MSS

Indicadores y Métricas de Servicios de Seguridad Gestionados

Aplicación Territorial España • Perspectiva Comparativa Mundial

Versión 1.0 — Abril 2026

"Responder con honestidad a esta encuesta no es un ejercicio de contricción corporativa, sino el primer acto genuino de madurez en ciberseguridad."

PRESENTACIÓN Y PROPÓSITO

Esta encuesta ha sido diseñada para que directivos, responsables técnicos y gestores de riesgo de organizaciones españolas puedan diagnosticar con precisión el estado de madurez de sus Servicios de Seguridad Gestionados (MSS), la calidad de los indicadores que monitorizan y la alineación de sus prácticas con los marcos regulatorios vigentes (ENS, NIS2, DORA, ISO 27001, GDPR).

Tiempo estimado de respuesta: 25–45 minutos según nivel de detalle elegido.

Confidencialidad: Las respuestas son anónimas a nivel individual. Los datos agregados se usarán exclusivamente para producir el Índice de Madurez Global MSS (IGM-MSS) de la organización.

Perfiles respondientes recomendados: CISO, CTO, CIO, Director/a de Operaciones, Responsable de Cumplimiento, Director/a de Riesgos, Gestor/a del SOC interno o externo.

BLOQUE 0 — PERFIL ORGANIZACIONAL

Las siguientes preguntas permiten contextualizar sus respuestas. Sin contexto, los indicadores son números huérfanos en busca de sentido.

P0.1 — Sector de actividad principal

Seleccione la opción que mejor describe el sector primario de su organización:

- ☐ Banca, seguros y servicios financieros
- ☐ Energía (electricidad, gas, petróleo, renovables)
- ☐ Transporte y logística (aéreo, marítimo, ferroviario, viario)
- ☐ Telecomunicaciones y proveedores de servicios digitales
- ☐ Administración Pública (central, autonómica, local)
- ☐ Sanidad y servicios sociales
- ☐ Agua y saneamiento
- ☐ Industria manufacturera y fabricación avanzada
- ☐ Defensa e industria aeroespacial
- ☐ Alimentación y agroindustria
- ☐ Educación e investigación
- ☐ Comercio minorista y distribución
- ☐ Tecnología y software (incluido proveedor de MSS/MSSP)
- ☐ Construcción e infraestructuras
- ☐ Medios de comunicación y entretenimiento
- ☐ Otro sector no listado: ____

P0.2 — Tamaño de la organización (número de empleados)

- ☐ Microempresa: menos de 10 empleados
- ☐ Pequeña empresa: entre 10 y 49 empleados
- ☐ Mediana empresa: entre 50 y 249 empleados
- ☐ Gran empresa: entre 250 y 999 empleados
- ☐ Corporación: 1.000 o más empleados
- ☐ Organismo público con más de 500 usuarios de sistemas

P0.3 — Ámbito geográfico de operaciones

- ☐ Exclusivamente local (municipio o provincia)
- ☐ Regional (una o varias Comunidades Autónomas)
- ☐ Nacional (toda España)
- ☐ Europeo (España + otros países UE)
- ☐ Internacional con actividad en España (sede o filial relevante)
- ☐ Global con presencia en más de 10 países

P0.4 — Perfil del respondente

- ☐ CISO / Responsable de Seguridad de la Información
- ☐ CTO / Director/a de Tecnología
- ☐ CIO / Director/a de Sistemas
- ☐ Director/a de Riesgos o Cumplimiento
- ☐ Director/a de Operaciones (COO)
- ☐ Responsable del SOC interno
- ☐ Gestor/a de contratos MSS/MSSP
- ☐ Consultor/a externo con acceso privilegiado
- ☐ Otro perfil directivo: ____

P0.5 — ¿Su organización está clasificada como Operador Esencial o Entidad Importante bajo NIS2 / Ley de Gobernanza de Ciberseguridad en tramitación?

- ☐ Sí, como Operador Esencial (sectores críticos de alta criticidad: energía, banca, agua, transporte, salud, infraestructuras digitales)
- ☐ Sí, como Entidad Importante (otros sectores: servicios postales, gestión de residuos, alimentación, manufactura crítica, etc.)
- ☐ Estamos evaluando si nos aplica, pero aún no lo tenemos claro — lo cual dice bastante
- ☐ No estamos clasificados como entidad regulada bajo NIS2
- ☐ Desconocemos nuestra clasificación regulatoria

BLOQUE 1 — GOBIERNO Y ESTRATEGIA DE CIBERSEGURIDAD

Porque una estrategia de ciberseguridad sin gobierno es como una orquesta sin director: mucho ruido, poca sinfonía.

P1.1 — ¿Dispone su organización de una Estrategia de Ciberseguridad formalmente aprobada y documentada?

- ☐ Sí, aprobada por el Consejo de Administración o máximo órgano de gobierno, con revisión anual
- ☐ Sí, aprobada por la Dirección General, con revisión periódica aunque no siempre anual
- ☐ Existe un documento estratégico, pero no ha sido formalmente aprobado a nivel ejecutivo
- ☐ Está en elaboración — llevamos «en elaboración» desde hace más tiempo del recomendable
- ☐ No existe estrategia documentada; operamos por intuición colectiva e incidentes motivadores
- ☐ No procede para nuestra organización (especifique el motivo): ____

P1.2 — ¿Con qué frecuencia revisa su organización la Estrategia de Ciberseguridad?

- ☐ Revisión continua integrada en el ciclo de gestión de riesgos
- ☐ Anualmente, con ajustes por cambios significativos del entorno
- ☐ Cada dos años, como mínimo exigido por el ENS para sistemas de categoría MEDIA/ALTA
- ☐ Cuando ocurre un incidente relevante (revisión reactiva pura)
- ☐ No se revisa con periodicidad establecida
- ☐ Nunca ha sido revisada desde su elaboración original

P1.3 — ¿Existe un CISO (Chief Information Security Officer) o función equivalente en su organización?

- ☐ Sí, CISO o equivalente con dedicación exclusiva, dependencia directa del CEO/Consejo
- ☐ Sí, función CISO combinada con otros roles (CTO, CIO, DPO) — multiplex inevitable
- ☐ Sí, CISO subcontratado como servicio (vCISO / CISO-as-a-Service)
- ☐ Existe un responsable de seguridad sin el título ni la autoridad formal de CISO
- ☐ No existe una función específica de seguridad de la información
- ☐ La seguridad es responsabilidad colectiva de todos, lo que en la práctica significa de nadie

P1.4 — ¿El Consejo de Administración o la Alta Dirección recibe informes periódicos sobre el estado de ciberseguridad?

- ☐ Sí, informes mensuales o trimestrales con KPIs cuantificados y tendencias
- ☐ Sí, con periodicidad semestral o anual, habitualmente en formato ejecutivo
- ☐ Solo cuando hay incidentes significativos (modo «portador de malas noticias»)
- ☐ No, la Alta Dirección delega completamente en el equipo técnico sin seguimiento activo
- ☐ No, porque la Alta Dirección considera que la ciberseguridad «es cosa de informática»

P1.5 — ¿Ha completado la Alta Dirección de su organización formación específica en ciberseguridad tal como exige el artículo 20 de la Directiva NIS2?

- ☐ Sí, formación completada y documentada para todos los miembros de la Alta Dirección
- ☐ Sí, formación completada para la mayoría, con pendientes en seguimiento
- ☐ Formación en proceso de planificación para el próximo año
- ☐ No, pero somos conscientes de la obligación regulatoria
- ☐ No, y desconocíamos que NIS2 lo exige expresamente
- ☐ No aplica (no sujetos a NIS2)

P1.6 — ¿Dispone su organización de un Comité de Seguridad de la Información activo y operativo?

- ☐ Sí, con reuniones mínimo trimestrales, actas documentadas y seguimiento de acuerdos
- ☐ Sí, aunque las reuniones son irregulares y el seguimiento de acuerdos es mejorable
- ☐ Existe formalmente pero rara vez se reúne en la práctica
- ☐ No existe comité formal, pero hay coordinación informal entre áreas
- ☐ No existe ninguna estructura de gobernanza de seguridad

P1.7 — ¿Cuál es el presupuesto dedicado a ciberseguridad como porcentaje del presupuesto total de TI?

- ☐ Más del 15%: gestión proactiva avanzada, nivel de referencia internacional
- ☐ Entre el 10% y el 15%: por encima de la media del mercado
- ☐ Entre el 5% y el 10%: en la franja media del mercado
- ☐ Entre el 1% y el 5%: por debajo de los umbrales recomendados por ENISA
- ☐ Menos del 1%: inversión simbólica con riesgo real significativo
- ☐ No existe una partida presupuestaria específica para ciberseguridad
- ☐ Desconozco cuál es ese porcentaje — lo que ya de por sí es un indicador

BLOQUE 2 — MODELO DE PROVISIÓN DE SEGURIDAD (MSS/MSSP)

Donde averiguamos si su seguridad está en manos propias, ajenas o en una nebulosa gestionada con buena voluntad.

P2.1 — ¿Cómo gestiona principalmente su organización los servicios de ciberseguridad?

- ☐ Completamente interno: SOC propio, equipo de seguridad dedicado y autofinanciado
- ☐ Modelo híbrido co-gestionado: capacidades propias complementadas con MSSP externo
- ☐ Externalización total a uno o varios proveedores MSS/MSSP especializados
- ☐ Modelo de vCISO + servicios puntuales bajo demanda
- ☐ Dependemos de las capacidades de seguridad del proveedor de TI principal (no especializado)
- ☐ Sin modelo definido: reaccionamos a los incidentes con los recursos disponibles en cada momento

P2.2 — Si dispone de un proveedor MSS externo, ¿cuántos proveedores gestiona simultáneamente?

- ☐ Un único proveedor MSS principal (modelo consolidado)
- ☐ Dos proveedores con roles complementarios
- ☐ Entre tres y cinco proveedores especializados por dominio (SOC, pentest, CTI, MDR...)
- ☐ Más de cinco proveedores, con los desafíos de coordinación que ello implica
- ☐ No disponemos de proveedor MSS externo
- ☐ Desconozco el número exacto de proveedores activos (señal de gobernanza mejorable)

P2.3 — ¿Su proveedor MSS principal está domiciliado y controlado en la Unión Europea?

Nota: Según el análisis de mercado ENISA 2025, el 51% de los proveedores MSS que operan en Europa están bajo control de entidades no europeas, aunque tengan sede en la UE.

- ☐ Sí, la empresa y su cadena de control accionarial son europeas
- ☐ La sede está en Europa pero la matriz controladora es una empresa no-UE (EE.UU., Asia...)
- ☐ No estamos seguros de la estructura accionarial real de nuestro proveedor
- ☐ Nuestro proveedor es claramente de origen no-UE (EE.UU., Israel, etc.)
- ☐ No disponemos de proveedor MSS externo
- ☐ No habíamos considerado este aspecto como relevante hasta este momento

P2.4 — ¿Qué servicios MSS tiene contratados externamente? (Marque todos los que apliquen)

- ☐ Monitorización y gestión SIEM (Security Information and Event Management)
- ☐ MDR — Managed Detection and Response (detección y respuesta gestionadas)
- ☐ SOC como servicio (SOC-as-a-Service)
- ☐ Gestión de vulnerabilidades (scanning, priorización, remediación guiada)
- ☐ Threat Intelligence (CTI) — inteligencia de amenazas
- ☐ Gestión de identidades y acceso privilegiado (IAM/PAM)
- ☐ Respuesta a Incidentes (IR) — servicio de guardia 24×7
- ☐ Pruebas de penetración periódicas (pentest, red team)
- ☐ Seguridad cloud gestionada (CSPM, CASB)
- ☐ Gestión de cumplimiento normativo (ENS, NIS2, ISO 27001, DORA)
- ☐ Formación y simulacros de phishing
- ☐ Gestión de certificados y PKI
- ☐ DDoS Protection as a Service
- ☐ Threat Hunting proactivo
- ☐ Seguridad OT/ICS industrial
- ☐ Ejercicios de continuidad de negocio y simulacros de crisis ciber
- ☐ Ninguno de los anteriores

P2.5 — ¿Dispone de un contrato SLA (Service Level Agreement) formalmente firmado con su proveedor MSS?

- ☐ Sí, con métricas cuantificadas, penalizaciones por incumplimiento y revisión periódica
- ☐ Sí, pero contiene métricas genéricas no adaptadas a nuestro perfil de riesgo
- ☐ Existe un contrato de servicios estándar sin SLA específico de seguridad
- ☐ Relación contractual básica sin SLA; confiamos en la buena voluntad del proveedor
- ☐ No existe contrato formal; la relación es verbal o basada en pedidos puntuales
- ☐ No disponemos de proveedor MSS externo

P2.6 — ¿Qué métricas incluye explícitamente su SLA con el proveedor MSS? (Marque todos los que apliquen)

- ☐ MTTD (Tiempo Medio de Detección) con umbral definido
- ☐ MTTC (Tiempo Medio de Contención) con umbral definido
- ☐ MTTR (Tiempo Medio de Respuesta/Recuperación) con umbral definido
- ☐ Tasa de falsos positivos máxima aceptable
- ☐ Disponibilidad del servicio (uptime %) 24×7×365
- ☐ Tiempo de respuesta ante incidentes P1 (críticos)
- ☐ Porcentaje de cobertura de activos monitorizados
- ☐ Frecuencia y profundidad de informes periódicos
- ☐ Tiempos de notificación regulatoria (24h/72h bajo NIS2)
- ☐ Penalizaciones económicas por incumplimiento de niveles
- ☐ Nuestro SLA no incluye métricas cuantificadas
- ☐ No disponemos de SLA con proveedor MSS

P2.7 — En una escala de 1 (pésimo) a 5 (excelente), ¿cómo valoraría la capacidad de personalización de métricas que le ofrece su proveedor MSS?

- ☐ 1 — El proveedor nos da lo que quiere; las métricas son suyas, no nuestras
- ☐ 2 — Hay cierta flexibilidad, pero los cambios reales son lentos y costosos
- ☐ 3 — Personalización moderada; algunos KPIs adaptados, otros genéricos
- ☐ 4 — Buena capacidad de personalización con revisión periódica
- ☐ 5 — Métricas completamente adaptadas a nuestro perfil de riesgo y sector
- ☐ No disponemos de proveedor MSS externo

BLOQUE 3 — INDICADORES OPERATIVOS DE DETECCIÓN Y RESPUESTA

El corazón cuantitativo del servicio. Aquí la ironía cede el paso a los decimales.

P3.1 — ¿Monitoriza su organización el MTTD (Mean Time to Detect)?

- ☐ Sí, medido y reportado de forma continua con dashboard en tiempo real
- ☐ Sí, medido mensualmente como parte del informe SOC
- ☐ Se estima de forma aproximada, sin medición sistemática
- ☐ No se mide, pero somos conscientes de que deberíamos hacerlo
- ☐ Desconocemos este indicador
- ☐ No aplica a nuestro modelo de seguridad actual

P3.2 — ¿Cuál es el MTTD medio de su organización para incidentes de severidad ALTA o CRÍTICA?

[Responda con el valor real o la mejor estimación disponible. Si no lo sabe, marque la última opción.]

- ☐ Menos de 15 minutos — Nivel de excelencia operativa con detección automatizada
- ☐ Entre 15 minutos y 1 hora — Muy por encima de la media del mercado
- ☐ Entre 1 y 4 horas — En la franja alta del mercado
- ☐ Entre 4 y 24 horas — Nivel medio-bajo con margen significativo de mejora
- ☐ Entre 1 y 7 días — Zona de riesgo: el atacante tiene tiempo para moverse con comodidad
- ☐ Más de 7 días — Situación de riesgo crítico
- ☐ No disponemos de datos de MTTD medidos

P3.3 — ¿Monitoriza su organización el MTTR (Mean Time to Respond/Recover)?

- ☐ Sí, medido y reportado de forma continua con umbrales SLA definidos
- ☐ Sí, medido por incidente mayor pero no de forma sistemática para todos los incidentes
- ☐ Se registra informalmente en los tickets de incidentes sin análisis agregado
- ☐ No se mide, aunque reconocemos su importancia
- ☐ Desconocemos este indicador

P3.4 — ¿Cuál es el MTTR medio de su organización para incidentes de severidad ALTA o CRÍTICA?

- ☐ Menos de 1 hora — Capacidad de respuesta de élite
- ☐ Entre 1 y 4 horas — Por encima del umbral recomendado por buenas prácticas
- ☐ Entre 4 y 24 horas — Nivel aceptable con margen de mejora
- ☐ Entre 1 y 3 días — Zona de riesgo para operaciones críticas
- ☐ Entre 3 y 7 días — Exposición prolongada inaceptable en entornos críticos
- ☐ Más de 7 días — Situación grave de resiliencia
- ☐ No disponemos de datos de MTTR medidos

P3.5 — ¿Cuál es la tasa de falsos positivos de su sistema de detección (SIEM/MDR/EDR)?

- ☐ Menos del 5%: alta precisión, analistas centrados en amenazas reales
- ☐ Entre el 5% y el 15%: nivel aceptable con optimización recomendable
- ☐ Entre el 15% y el 30%: señal de ruido que genera fatiga en analistas
- ☐ Más del 30%: volumen de ruido que compromete la eficacia operativa
- ☐ No medimos la tasa de falsos positivos
- ☐ Desconocemos el concepto de falso positivo en este contexto

P3.6 — ¿Qué porcentaje de sus activos críticos están monitorizados en tiempo real (Asset Coverage Ratio)?

- ☐ Más del 95%: cobertura prácticamente total
- ☐ Entre el 80% y el 95%: buena cobertura con algunos gaps identificados
- ☐ Entre el 60% y el 80%: cobertura parcial con riesgos en los márgenes no cubiertos
- ☐ Entre el 40% y el 60%: cobertura insuficiente, sobre todo en activos legacy o OT
- ☐ Menos del 40%: monitorización selectiva con significativa superficie desprotegida
- ☐ No disponemos de datos sobre cobertura de activos

P3.7 — ¿Su organización realiza gestión continua de vulnerabilidades?

- ☐ Sí, con escaneo automatizado continuo, priorización por criticidad real y remediación tracked
- ☐ Sí, con escaneos periódicos (mínimo mensual) y proceso formal de remediación
- ☐ Escaneos esporádicos, generalmente antes de auditorías o tras incidentes
- ☐ Solo análisis puntuales realizados por terceros (pentest anual o bienal)
- ☐ No realizamos gestión de vulnerabilidades de forma sistemática

P3.8 — ¿Cuál es el tiempo medio de remediación de vulnerabilidades CRÍTICAS (CVSS $\geq$ 9.0) tras su identificación?

- ☐ Menos de 24 horas: velocidad de respuesta que envidiaría CISA con su KEV
- ☐ Entre 1 y 7 días: nivel óptimo para vulnerabilidades activamente explotadas
- ☐ Entre 7 y 30 días: aceptable para vulnerabilidades sin exploit público activo
- ☐ Entre 30 y 90 días: zona de riesgo considerable
- ☐ Más de 90 días: exposición prolongada a vulnerabilidades críticas
- ☐ No disponemos de métricas de tiempo de remediación

P3.9 — ¿Realiza su organización ejercicios de Threat Hunting proactivo?

(Búsqueda activa de amenazas que han evadido los controles automáticos de detección)

- ☐ Sí, con equipo dedicado y periodicidad mínima mensual
- ☐ Sí, de forma trimestral, utilizando hipótesis basadas en CTI
- ☐ Threat Hunting reactivo tras incidentes o indicadores de compromiso externos
- ☐ Lo realiza nuestro proveedor MSS como parte del servicio contratado
- ☐ No realizamos Threat Hunting
- ☐ Desconocemos en qué consiste el Threat Hunting

P3.10 — ¿Dispone su organización de capacidad de respuesta a incidentes disponible 24 horas al día, 7 días a la semana, 365 días al año?

- ☐ Sí, capacidad interna 24x7 con analistas en turno
- ☐ Sí, mediante contrato de guardia con MSSP especializado en IR
- ☐ Sí, combinando capacidad interna fuera de horario con servicio MSS de guardia
- ☐ Cobertura en horario laboral; fuera de ese horario, dependemos de la buena fortuna
- ☐ No disponemos de capacidad 24x7; nuestra cobertura tiene flancos abiertos
- ☐ Solo respuesta reactiva cuando se detecta el incidente (que puede ser cuando ya es tarde)

BLOQUE 4 — CUMPLIMIENTO NORMATIVO Y MARCOS REGULATORIOS

Donde la ley entra por la ventana y el CISO sale corriendo hacia el Consejo con el anteproyecto bajo el brazo.

P4.1 — ¿En qué estado se encuentra la conformidad de su organización con el Esquema Nacional de Seguridad (ENS)?

(Aplica a administraciones públicas y sus proveedores tecnológicos)

- ☐ Certificación ENS vigente de categoría ALTA, con última auditoría satisfactoria
- ☐ Certificación ENS vigente de categoría MEDIA, con seguimiento activo
- ☐ Declaración de Conformidad ENS emitida, en proceso de certificación formal
- ☐ En proceso de adecuación al ENS, sin certificación activa
- ☐ El ENS no aplica a nuestra organización
- ☐ Desconocemos si el ENS aplica a nuestra organización — lo cual puede ser costoso en breve

P4.2 — ¿En qué estado se encuentra la preparación de su organización para cumplir con la Directiva NIS2 / Ley de Gobernanza de Ciberseguridad?

- ☐ Análisis de brechas completo, plan de acción en ejecución con hitos definidos
- ☐ Análisis de brechas en curso, plan de acción pendiente de aprobación presupuestaria
- ☐ Hemos identificado los requisitos pero aún no hemos iniciado la implementación formal
- ☐ Esperando a que la ley española sea definitivamente aprobada para iniciar acciones
- ☐ La NIS2 no nos aplica (o eso creemos) y no hemos realizado ningún análisis
- ☐ Desconocemos el alcance de la NIS2 y qué obligaciones nos correspondería asumir

P4.3 — ¿Cumple su organización con los plazos de notificación de incidentes exigidos por NIS2?

(24 horas para alerta inicial, 72 horas para notificación formal, 1 mes para informe completo)

- ☐ Sí, tenemos un procedimiento documentado que cumple los tres plazos con holgura
- ☐ Cumplimos los plazos, aunque el proceso es tenso y mejorable en la práctica
- ☐ Probablemente los cumpliríamos para incidentes mayores, pero sin garantías para menores
- ☐ No disponemos de procedimientos formales de notificación regulatoria
- ☐ Desconocíamos estos plazos de notificación hasta leer esta pregunta

P4.4 — ¿Dispone su organización de certificación ISO/IEC 27001 vigente?

- ☐ Sí, certificación vigente, con última auditoría de seguimiento satisfactoria
- ☐ Certificación en proceso, con análisis de brechas y plan de implementación activo
- ☐ Hemos adoptado ISO 27001 como marco de referencia sin certificación formal
- ☐ No tenemos ISO 27001, pero estamos evaluando su adopción
- ☐ No hemos considerado la certificación ISO 27001

P4.5 — Para organizaciones del sector financiero: ¿En qué estado se encuentra la conformidad con DORA (Digital Operational Resilience Act)?

(En vigor desde enero 2025)

- ☐ Conformidad alcanzada, con evaluaciones de resiliencia realizadas y proveedores TIC auditados
- ☐ En proceso avanzado de adaptación, con gaps identificados y remediación en curso
- ☐ En fase inicial de análisis; la complejidad de DORA es real y la hemos subestimado
- ☐ DORA no aplica a nuestra organización
- ☐ Desconocíamos que DORA ya está en vigor desde enero 2025

P4.6 — ¿Realiza su organización evaluaciones formales del riesgo de ciberseguridad con periodicidad definida?

- ☐ Sí, evaluaciones anuales completas + actualizaciones continuas del registro de riesgos
- ☐ Sí, evaluaciones anuales con metodología documentada (MAGERIT, ISO 31000, NIST RMF)
- ☐ Evaluaciones periódicas pero sin metodología formal y sin registro estructurado
- ☐ Solo evaluamos el riesgo de forma reactiva tras incidentes o cambios importantes
- ☐ No realizamos evaluaciones formales de riesgo de ciberseguridad

P4.7 — ¿Gestiona formalmente su organización el riesgo de ciberseguridad de terceros/proveedores?

- ☐ Sí, con programa formal de TPRM (Third Party Risk Management) que cubre toda la cadena de suministro crítica
- ☐ Sí, con evaluaciones de seguridad para proveedores críticos pero sin programa global
- ☐ Incluimos cláusulas de seguridad en contratos pero sin evaluación técnica sistemática
- ☐ Confiamos en las certificaciones y declaraciones del proveedor sin verificación propia
- ☐ No gestionamos el riesgo de proveedores de forma diferenciada de otros riesgos operativos
- ☐ No hemos considerado que nuestros proveedores representen un vector de riesgo significativo

BLOQUE 5 — RESILIENCIA DIGITAL Y CONTINUIDAD DE NEGOCIO

Porque la ciberseguridad perfecta no existe, pero la capacidad de sobrevivir al incidente que inevitablemente llegará, esa sí puede construirse.

P5.1 — ¿Dispone su organización de un Plan de Continuidad de Negocio (BCP) que incorpore escenarios de ciberincidente?

- ☐ Sí, BCP documentado, probado y actualizado en los últimos 12 meses con escenarios ciber específicos
- ☐ Sí, BCP existente pero los escenarios de ciberincidente están poco desarrollados
- ☐ Plan de Recuperación ante Desastres (DRP) técnico, sin BCP formal que cubra el negocio
- ☐ En proceso de elaboración del BCP
- ☐ No disponemos de BCP; la continuidad de negocio es una preocupación para el futuro
- ☐ Confiamos en la resiliencia natural de la organización, que en los últimos años ha demostrado ser sorprendentemente frágil

P5.2 — ¿Con qué frecuencia realiza su organización simulacros o ejercicios de ciber crisis?

- ☐ Al menos trimestralmente, con diferentes escenarios de amenaza
- ☐ Anualmente, con ejercicios de tabletop que involucren a la dirección
- ☐ Cada dos años, generalmente coincidiendo con auditorías ENS o ISO 27001
- ☐ Solo cuando un incidente real actúa como simulacro no deseado
- ☐ No realizamos simulacros de ciber crisis
- ☐ No vemos el valor de los simulacros hasta que ocurre el incidente que los justifica

P5.3 — ¿Cuáles son los objetivos de recuperación formalmente definidos de su organización?

(RTO: tiempo máximo de interrupción aceptable; RPO: pérdida máxima de datos aceptable)

- ☐ RTO < 4 horas y RPO < 1 hora para sistemas críticos: nivel de disponibilidad de misión crítica
- ☐ RTO < 24 horas y RPO < 4 horas para sistemas críticos: nivel alto
- ☐ RTO < 72 horas y RPO < 24 horas: nivel estándar
- ☐ RTO y RPO definidos pero no probados en condiciones reales
- ☐ Sin RTO/RPO definidos formalmente
- ☐ Desconocemos el significado de RTO y RPO

P5.4 — ¿Dispone su organización de copias de seguridad verificadas y aisladas (air-gapped o equivalente) para sus sistemas y datos críticos?

- ☐ Sí, backups inmutables con verificación de integridad periódica y copias offsite/air-gapped
- ☐ Sí, backups regulares con pruebas de restauración periódicas
- ☐ Backups regulares pero sin pruebas de restauración documentadas (confianza sin verificación)
- ☐ Backups parciales que no cubren todos los sistemas críticos
- ☐ Backups en la misma red que los sistemas de producción (vulnerables al ransomware)
- ☐ Sin política formal de backup: vivimos de la esperanza

P5.5 — ¿Ha experimentado su organización algún incidente de ransomware en los últimos tres años?

- ☐ No, y tenemos controles que nos dan confianza razonable de que somos un objetivo poco atractivo
- ☐ No, aunque reconocemos que es cuestión de tiempo o de suerte
- ☐ Sí, con impacto limitado y recuperación completa sin pago de rescate
- ☐ Sí, con impacto significativo pero sin llegar al pago del rescate
- ☐ Sí, con impacto grave y pago de rescate (en criptomoneda, inevitablemente)
- ☐ Sí, con impacto catastrófico que alteró de forma permanente las operaciones
- ☐ Prefiero no responder a esta pregunta (respuesta que por sí sola habla mucho)

BLOQUE 6 — MADUREZ TECNOLÓGICA Y ARQUITECTURA DE SEGURIDAD

De la tecnología que hay en el catálogo a la que realmente funciona en producción, suele haber una distancia filosófica considerable.

P6.1 — ¿Dispone su organización de un SIEM (Security Information and Event Management) operativo?

- ☐ Sí, SIEM de nueva generación con UEBA, SOAR integrado y correlación avanzada
- ☐ Sí, SIEM operativo con reglas de correlación actualizadas y analistas dedicados
- ☐ Sí, SIEM desplegado pero con capacidades limitadas por falta de afinación o analistas
- ☐ SIEM planificado pero no desplegado
- ☐ No disponemos de SIEM
- ☐ Dependemos del SIEM de nuestro proveedor MSS

P6.2 — ¿Ha adoptado su organización una arquitectura Zero Trust?

(Principio «nunca confiar, siempre verificar», sin perímetro de seguridad implícito)

- ☐ Sí, Zero Trust implementado de forma integral: identidad, dispositivo, red, aplicación y datos
- ☐ Sí, en proceso de implementación con fases prioritarias completadas (MFA, microsegmentación)
- ☐ Adoptamos principios Zero Trust de forma parcial sin un programa formal
- ☐ Zero Trust en hoja de ruta pero no iniciado
- ☐ No, seguimos con modelo perimetral tradicional (castle-and-moat)
- ☐ Conocemos el concepto pero su implementación nos parece técnicamente inalcanzable con nuestros recursos actuales

P6.3 — ¿Dispone su organización de autenticación multifactor (MFA) implementada?

- ☐ MFA obligatorio para todos los usuarios en todos los sistemas, incluidos proveedores terceros
- ☐ MFA obligatorio para usuarios privilegiados y accesos críticos; parcial para el resto
- ☐ MFA disponible pero opcional; la adopción real es inferior al 70%
- ☐ MFA implantado solo para accesos remotos (VPN, correo externo)
- ☐ Sin MFA: contraseñas únicas como única barrera de autenticación
- ☐ Estamos migrando de contraseñas a MFA sin una fecha comprometida de finalización

P6.4 — ¿Dispone su organización de soluciones XDR (Extended Detection and Response) o EDR avanzado?

- ☐ Sí, XDR integrado con visibilidad completa de endpoints, red, identidad y cloud
- ☐ Sí, EDR avanzado con capacidades de detección comportamental en endpoints críticos
- ☐ Antivirus/EPP de nueva generación con algunas capacidades EDR
- ☐ Soluciones antivirus tradicionales sin capacidades de detección avanzada
- ☐ No disponemos de protección avanzada de endpoints
- ☐ Dependemos de las herramientas incluidas en el contrato con nuestro proveedor MSS

P6.5 — ¿Gestiona su organización formalmente el inventario de activos tecnológicos (hardware, software, cloud)?

- ☐ Sí, inventario automatizado y actualizado en tiempo real (CMDB) integrado con el SIEM
- ☐ Sí, inventario manual actualizado trimestralmente con responsables asignados
- ☐ Inventario parcial que cubre los activos conocidos pero con shadow IT sin mapear
- ☐ Inventario desactualizado que raramente refleja la realidad del parque tecnológico
- ☐ Sin inventario formal: gestionamos lo que conocemos y esperamos no olvidar nada importante
- ☐ El shadow IT en nuestra organización supera con creces al TI formal

P6.6 — ¿Dispone su organización de entornos OT/ICS (Operational Technology / Industrial Control Systems)?

(Aplica a energía, manufactura, agua, transporte, infraestructuras críticas)

- ☐ Sí, con segmentación OT/IT documentada, monitorización específica y controles adaptados
- ☐ Sí, con segmentación parcial OT/IT pero sin monitorización específica de protocolos industriales
- ☐ Sí, con convergencia IT/OT sin segmentación adecuada (riesgo alto)
- ☐ No disponemos de entornos OT/ICS
- ☐ Desconocemos el alcance exacto de nuestros sistemas OT

BLOQUE 7 — CAPITAL HUMANO Y CULTURA DE CIBERSEGURIDAD

La primera línea de defensa suele ser también la más porosa: los seres humanos.

P7.1 — ¿Dispone su organización de un programa formal de formación y concienciación en ciberseguridad para todos los empleados?

- ☐ Sí, programa continuo con módulos adaptados por rol, pruebas y seguimiento de completitud
- ☐ Sí, formación anual obligatoria con evaluación de comprensión
- ☐ Formaciones puntuales sin programa estructurado
- ☐ Materiales de concienciación disponibles pero sin seguimiento de adopción
- ☐ Sin programa de formación: confiamos en el sentido común de nuestros empleados (un activo notoriamente impredecible)

P7.2 — ¿Realiza su organización simulacros de phishing periódicos?

- ☐ Sí, con frecuencia mínima trimestral, resultados analizados y plan de mejora asociado
- ☐ Sí, con frecuencia anual o bienal como verificación del nivel de concienciación
- ☐ Los hemos realizado de forma puntual sin periodicidad establecida
- ☐ No realizamos simulacros de phishing
- ☐ No realizamos simulacros de phishing porque los resultados nos darían pánico

P7.3 — ¿Cuál es la tasa de clics en simulacros de phishing de su organización (porcentaje de empleados que clican en el enlace malicioso simulado)?

- ☐ Menos del 3%: nivel de excelencia, organización altamente concienciada
- ☐ Entre el 3% y el 8%: nivel bueno, con margen de mejora continua
- ☐ Entre el 8% y el 15%: nivel medio que requiere intervención formativa específica
- ☐ Entre el 15% y el 30%: nivel preocupante
- ☐ Más del 30%: nivel de alto riesgo humano
- ☐ No realizamos medición de este indicador

P7.4 — ¿Cuál es la brecha de talento en ciberseguridad que experimenta su organización?

- ☐ Sin brecha significativa: plantilla cubierta y con retención satisfactoria
- ☐ Brecha moderada: vacantes puntuales en roles especializados difíciles de cubrir
- ☐ Brecha significativa: varios puestos clave sin cubrir de forma crónica
- ☐ Brecha grave: dependemos de proveedores externos por incapacidad de contratar talento interno
- ☐ La brecha es tan severa que los roles de ciberseguridad son absorbidos por IT generalista

P7.5 — ¿Tiene su organización un programa de gestión de amenazas internas (Insider Threat Program)?

- ☐ Sí, con monitorización de comportamiento (UEBA), controles de acceso mínimo privilegio y protocolo de gestión
- ☐ Sí, con políticas y procedimientos documentados aunque sin tecnología UEBA específica
- ☐ Controles básicos (separación de funciones, revisión de accesos) sin programa formal
- ☐ No, la amenaza interna no está en nuestro modelo de riesgo formalizado
- ☐ No, y somos conscientes de que debería estarlo

BLOQUE 8 — INTELIGENCIA DE AMENAZAS Y VIGILANCIA DIGITAL

Conocer al adversario antes de que llame a la puerta: el arte de la CTI aplicada.

P8.1 — ¿Consume su organización inteligencia de amenazas (Threat Intelligence / CTI) de forma activa?

- ☐ Sí, CTI integrada en el SIEM y los procesos de detección, con plataforma TIP dedicada
- ☐ Sí, suscripción a feeds de CTI comerciales con análisis e integración manual
- ☐ Consumimos información de fuentes abiertas (OSINT) de forma esporádica
- ☐ Recibimos informes de CTI de nuestro proveedor MSS pero sin integración técnica activa
- ☐ No consumimos CTI de ningún tipo
- ☐ Desconocemos el concepto de Threat Intelligence en el contexto de MSS

P8.2 — ¿Participa su organización en plataformas de intercambio de información sobre amenazas?

- ☐ Sí, en ISAC sectorial (FS-ISAC, ENISA, RedNAC/CCN) y plataformas MISP o equivalente
- ☐ Sí, en alguna plataforma sectorial con participación activa (envío y recepción de IOCs)
- ☐ Solo recibimos información; no contribuimos con datos propios
- ☐ No participamos en plataformas de intercambio de información
- ☐ Desconocemos la existencia de estas plataformas en nuestro sector

P8.3 — ¿Realiza su organización vigilancia de la Dark Web y fuentes clandestinas sobre posibles filtraciones de datos?

- ☐ Sí, monitorización continua automatizada de filtraciones de credenciales, datos y propiedad intelectual
- ☐ Sí, mediante servicio MSS de Dark Web Monitoring
- ☐ Verificaciones puntuales tras incidentes o sospechas concretas
- ☐ No realizamos vigilancia de la Dark Web
- ☐ No sabíamos que existía este tipo de servicio

BLOQUE 9 — IMPACTO FINANCIERO, ACTUARIAL Y RETORNO DE INVERSIÓN

Porque al final del día, el Consejo de Administración habla euros, no CVEs.

P9.1 — ¿Cuantifica su organización el impacto económico de los incidentes de ciberseguridad?

- ☐ Sí, con metodología CRQ (Cyber Risk Quantification) documentada y modelo actuarial interno
- ☐ Sí, estimación del coste por incidente con alcance operativo y reputacional
- ☐ Cuantificación parcial de costes directos (respuesta, recuperación) sin indirectos
- ☐ Estimaciones informales sin metodología establecida
- ☐ No cuantificamos el impacto económico de los incidentes
- ☐ Calculamos el ROSI a posteriori solo cuando nos lo pide la alta dirección

P9.2 — ¿Dispone su organización de seguro de ciberriesgos (ciberseguro)?

- ☐ Sí, cobertura amplia que incluye: ransomware, responsabilidad ante terceros, lucro cesante, gestión de crisis
- ☐ Sí, cobertura básica con algunas exclusiones relevantes que conocemos
- ☐ Sí, pero con coberturas y exclusiones que no hemos revisado en detalle recientemente
- ☐ En proceso de contratación o renovación
- ☐ No disponemos de ciberseguro, aunque evaluamos su necesidad periódicamente
- ☐ No disponemos de ciberseguro ni lo hemos considerado necesario hasta ahora

P9.3 — ¿Ha experimentado su organización variación en las primas del ciberseguro en los últimos 12 meses?

(En España, el mercado registró un +12% de aumento de primas en 2025 según datos de AON)

- ☐ Reducción de primas gracias a mejora documentada de controles (la opción deseable)
- ☐ Primas estables, sin cambios significativos
- ☐ Aumento moderado (hasta el 15%) dentro del rango de mercado
- ☐ Aumento significativo (15%-50%) con dudas sobre justificación por parte del asegurador
- ☐ Aumento superior al 50%, con restricciones de cobertura adicionales
- ☐ No disponemos de ciberseguro

P9.4 — ¿Mide su organización el ROSI (Return on Security Investment)?

- ☐ Sí, con metodología formal y presentación periódica a la Alta Dirección
- ☐ Sí, de forma aproximada para justificar inversiones en proyectos de seguridad
- ☐ Intentamos medirlo pero nos resulta difícil por la complejidad de cuantificar «lo que no ocurrió»
- ☐ No medimos el ROSI
- ☐ Desconocemos la metodología ROSI

BLOQUE 10 — CRIPTOGRAFÍA POSTCUÁNTICA Y TECNOLOGÍAS EMERGENTES

El futuro amenaza, y esta vez no en metáfora: los ordenadores cuánticos descifrarán mañana lo que ciframos hoy.

P10.1 — ¿Ha evaluado su organización el riesgo de la amenaza cuántica sobre sus activos criptográficos?

- ☐ Sí, con inventario completo de activos criptográficos y análisis de vulnerabilidad a ataques cuánticos
- ☐ Evaluación parcial centrada en los sistemas más críticos
- ☐ Conocemos el riesgo pero aún no hemos iniciado la evaluación formal
- ☐ No hemos evaluado este riesgo
- ☐ Desconocíamos que la computación cuántica representa un riesgo para la criptografía actual

P10.2 — ¿Tiene su organización un plan de transición hacia criptografía postcuántica (PQC)?

(Estándares NIST PQC: ML-KEM/CRYSTALS-Kyber, ML-DSA, SLH-DSA publicados en agosto 2024)

- ☐ Sí, plan formal con cronograma de migración, responsables y presupuesto asignado
- ☐ Plan en elaboración, con análisis de impacto en curso
- ☐ En fase de sensibilización; aún no hemos iniciado planificación formal
- ☐ No tenemos plan; la transición postcuántica no está en nuestra hoja de ruta actual
- ☐ No aplica a nuestra organización (aunque sería prudente verificarlo)

P10.3 — ¿Gestiona su organización el riesgo «Harvest Now, Decrypt Later»?

(Adversarios que recopilan datos cifrados hoy para descifrarlos cuando dispongan de capacidad cuántica suficiente)

- ☐ Sí, identificados los activos con datos de larga vida y aplicadas medidas mitigadoras
- ☐ Conocemos el riesgo y lo hemos mencionado en evaluaciones, sin acciones concretas aún
- ☐ No gestionamos este riesgo específico
- ☐ Era la primera vez que escuchábamos este término antes de leer esta pregunta

P10.4 — ¿Utiliza su organización Inteligencia Artificial para mejorar sus capacidades de detección y respuesta?

- ☐ Sí, IA integrada en SIEM/XDR/SOAR con beneficios medidos (MTTD, FPR)
- ☐ Sí, herramientas con IA como componente de detección, aunque sin métricas de impacto
- ☐ En evaluación de soluciones IA para seguridad
- ☐ No utilizamos IA en nuestros procesos de seguridad
- ☐ Utilizamos IA pero aún no hemos medido su impacto real en la eficacia de detección

P10.5 — ¿Ha considerado su organización los riesgos de seguridad derivados del uso de IA generativa por sus empleados?

- ☐ Sí, con política documentada de uso de IA generativa y controles técnicos implementados
- ☐ Sí, hemos informado a los empleados sobre los riesgos pero sin controles técnicos formales
- ☐ No hay política específica de IA generativa; los empleados la usan sin directrices de seguridad
- ☐ Prohibimos el uso de IA generativa sin evaluar alternativas seguras
- ☐ No lo hemos considerado como un vector de riesgo de seguridad

BLOQUE 11 — SOBERANÍA DIGITAL Y DEPENDENCIA TECNOLÓGICA

Sobre si la llave de nuestra casa digital está en nuestras manos o en un data center del que preferiríamos no conocer la jurisdicción.

P11.1 — ¿Conoce su organización la localización geográfica y jurisdicción legal de todos sus datos críticos en la nube?

- ☐ Sí, con inventario completo de localización de datos y análisis de implicaciones de transferencia internacional
- ☐ Sí, para los datos más críticos; parcial para el resto
- ☐ Conocemos los principales proveedores cloud pero no la localización exacta de los datos
- ☐ No disponemos de visibilidad sobre la localización de nuestros datos en la nube
- ☐ Desconocíamos que la jurisdicción del dato es una dimensión de riesgo relevante

P11.2 — ¿Dispone su organización de estrategia de salida (exit strategy) para sus proveedores de MSS y cloud críticos?

- ☐ Sí, con plan documentado de transición, portabilidad de datos verificada y plazos estimados
- ☐ Sí, plan básico de salida, aunque no ha sido probado
- ☐ Dependencia identificada como riesgo, sin plan formal de mitigación
- ☐ No disponemos de estrategia de salida
- ☐ La dependencia de nuestros proveedores es tal que preferimos no pensar en los escenarios de salida

BLOQUE 12 — EVALUACIÓN GLOBAL Y PERSPECTIVA ESTRATÉGICA

La pregunta final de la clase: ¿dónde estamos y adónde queremos ir, más allá del cumplimiento reactivo?

P12.1 — En una escala de 1 a 5, ¿cuál es su valoración del nivel de madurez global de ciberseguridad de su organización?

- ☐ 1 — Inicial: procesos reactivos, sin estrategia, dependientes de individuos
- ☐ 2 — Gestionado: procesos básicos documentados, respuesta elemental a incidentes
- ☐ 3 — Definido: procesos estandarizados, SIEM operativo, cumplimiento básico
- ☐ 4 — Gestionado cuantitativamente: analítica avanzada, métricas, mejora continua
- ☐ 5 — Optimizado: IA-driven, threat hunting proactivo, ROSI positivo documentado

P12.2 — ¿Cuáles son los tres principales obstáculos para mejorar la madurez de ciberseguridad en su organización?

(Marque un máximo de tres)

- ☐ Presupuesto insuficiente para las necesidades reales de seguridad
- ☐ Falta de talento especializado y dificultad para retenerlo
- ☐ Escasa concienciación y apoyo de la Alta Dirección
- ☐ Complejidad y velocidad del entorno regulatorio (NIS2, ENS, DORA, GDPR)
- ☐ Deuda técnica acumulada y sistemas legacy difíciles de proteger
- ☐ Fragmentación de herramientas y proveedores difícil de integrar
- ☐ Ausencia de métricas claras para medir el retorno de la inversión en seguridad
- ☐ Resistencia cultural al cambio en la organización
- ☐ Dependencia excesiva de un único proveedor sin alternativas viables
- ☐ Otro obstáculo: ____

P12.3 — ¿Qué iniciativa considera más prioritaria para mejorar su postura de ciberseguridad en los próximos 12 meses?

(Marque un máximo de dos)

- ☐ Implementar o mejorar el programa de gestión de vulnerabilidades
- ☐ Desplegar o evolucionar la arquitectura Zero Trust
- ☐ Mejorar la capacidad de detección y respuesta (MDR/XDR)
- ☐ Completar la adecuación a NIS2 / ENS / ISO 27001
- ☐ Desarrollar el programa de gestión de riesgos de terceros (TPRM)
- ☐ Planificar la transición a criptografía postcuántica
- ☐ Reforzar la formación y cultura de seguridad
- ☐ Mejorar la capacidad de recuperación ante incidentes (resiliencia y BCP)
- ☐ Consolidar proveedores MSS y mejorar la calidad de los SLAs
- ☐ Implantar métricas de ROSI para mejorar la conversación con la Alta Dirección
- ☐ Otra iniciativa: ____

P12.4 — Espacio abierto para observaciones, contexto adicional o reflexiones que desee compartir

Si hasta aquí la encuesta le ha parecido incompleta, ingenuamente optimista o, en el extremo contrario, innecesariamente alarmista, este es el espacio para decirlo con toda la elocuencia que el tema merece.

[Campo de texto libre – sin límite de extensión]

AGRADECIMIENTO Y PRÓXIMOS PASOS

Gracias por dedicar su tiempo a esta encuesta. Sus respuestas contribuirán al cálculo del **Índice de Madurez Global MSS (IGM-MSS)** de su organización y a la elaboración del **Informe de Posicionamiento Sectorial** que recibirá en los próximos 15 días.

El informe incluirá:

- Puntuación IGM-MSS global y por pilares
- Posicionamiento percentil respecto al sector y al mercado nacional
- Brechas prioritarias identificadas
- Hoja de ruta de mejora recomendada alineada con NIS2/ENS/ISO 27001
- Benchmarking comparativo con datos agregados del mercado europeo (ENISA 2025)

Versión 1.0 · Abril 2026 · Basado en: ENISA MSS Market Analysis (junio 2025), ENISA ECSMAF V3.0 (marzo 2026), Balance INCIBE 2025, Plan Nacional de Ciberseguridad España (mayo 2025), NIS2 Directiva (UE) 2022/2555, ENS RD 311/2022, DORA, ISO/IEC 27001:2022, NIST CSF 2.0.